Cosmix Module Integration and Delivery Plan

Goal: Reduce development effort through selective clone reuse while preserving the existing Cosmix HR and security foundation and delivering accepted SRS workflows.

Status: Review draft v1.0. Prepared 12 October 2026, Asia Karachi. No implementation or five-month completion guarantee is implied.

1 Read This First

Bhai, hamara main backend wahi original cosmix-backend rahega jo Cosmix_Erp_software folder mein hai. Clone se useful UI, CRM, Projects aur Inventory ke developed parts lenge. Existing HR, login, permissions aur private documents replace nahi karenge. Accounts, Procurement, Manufacturing aur FSM ke useful parts review karke lenge, lekin missing business flow complete karna hoga. Pehle chhota CRM flow integrate karke actual effort measure karenge. Phir approved priority ke according Inventory aur Projects deliver karenge. Poora SRS aur five-month release scope alag cheezein hain; dono ko management approve karegi.

We recommend existing Cosmix plus selected donor reuse. This plan covers the whole delivery programme, including modules that cannot reasonably be treated as ready-made. It separates work we can adapt, work we must finish, and release choices that need management approval.

Read Sections 3 to 6 for architecture and exact reuse. Read Sections 9 to 14 for the complete module roadmap, security, schedule and ownership. Read Sections 15 and 16 before approving implementation.

What a complete integration means

A usable module includes connected screens, server-side validation and permissions, reviewed database changes, valid business transitions, audit evidence, retry/concurrency handling and tested cross-module effects. A copied folder, successful build, menu entry or empty-list API response is not module acceptance.

The five decisions to review first

- Retain the original backend, existing identity and sensitive HR flows.
- Approve CRM as the first small integration trial, with a fixed time budget and measurable exit criteria.
- Approve Inventory as a dedicated business module, not a renamed e-commerce stock counter.
- Select the priority five-month release; do not silently put every SRS requirement into that commitment.
- Authorize the verification approach before integration because the target repository currently excludes test projects from its solution.

2 Confirmed Projects and Evidence

Confirmed target folders

Backend: C:/Users/Huma.Khan/Downloads/Cosmix_Erp_software/cosmix-backend

Web: C:/Users/Huma.Khan/Downloads/Cosmix_Erp_software/cosmix_frotned

Mobile: C:/Users/Huma.Khan/Downloads/Cosmix_Erp_software/cosmix_mobile

Donor: C:/Users/Huma.Khan/Downloads/Cosmix_Erp_software/Cosmix_new/code

The user confirmed these folders from the screenshot. The different backend at C:/Users/Huma.Khan/Downloads/cosmix-backend is not the integration target and must remain untouched. The confirmed target HEAD is 70adaf7eeae4857b739c4b80cae6d8833ad163d2. Its existing Cosmix.Api.http modification must be preserved. Recheck all working-tree changes before future implementation.

What has actually been checked

The clone was audited at c4500264431523f7db7960bb3a759a15ca60f08e. Later uncommitted repairs addressed 19 exposed compile errors, paging/audit defects, stale test expectations and missing ERP schema provisioning. The new donor migration adds 34 tables; it was applied only to disposable test databases, not the target database.

The repaired donor passed 2975 Domain tests, 8593 Application tests, 46 architecture tests, 18 selected SQL integration tests and 140 frontend unit tests. These are donor checks. They do not prove the same features work in Cosmix, that all ERP workflows are complete, or that production security has been accepted.

The confirmed target contains SRS-specific HR hiring, employee changes, compensation decisions, authentication, private files and organisation flows. Its documentation explicitly states that full HR/attendance remains incomplete. The target inventory frontend currently describes folder boundaries only, not delivered screens or APIs.

Evidence limits

- The original SRS is a management-review draft. The AI-free expansion contains proposed contract details, not automatically approved company policy.
- The development report is a list of claims to verify, not proof of feature completion.
- The donor's complete integration/browser/production-release coverage has not been demonstrated.
- The original target has not received an equally deep full-system security audit in this review.
- No percentage-complete or saved-months claim is supported until requirements and acceptance evidence are mapped.
- AI features remain outside this programme, following the user's earlier scope decision. This does not remove the required face check at attendance check-in.

Global Constraints

- Preserve target authentication, employee identity, protected HR records and existing approval boundaries.
- Preserve unrelated working-tree changes and existing applied migration history.

- Do not copy donor users, passwords, tenant registry, account database, runtime configuration or migration history.
- Do not apply migrations to a real database without explicit approval, backup and target verification.
- Follow target module-specific repositories and services; do not introduce a second framework solely to copy a donor handler.
- Keep scope/ownership decisions server-side. Mobile and web never supply trusted authority or final stock balances.
- No default production accounts, fake provider success, exposed credentials or secrets in Git.
- Confirm the test strategy before implementation; do not silently restore removed test projects.

3 Target Architecture and Data Ownership

We will keep one deployable Cosmix API with Domain, Application, Infrastructure and Api projects. CRM, Inventory, Projects and later modules remain feature areas in that application. The web and mobile clients use the same business records through their appropriate authentication flows.

We will reuse donor functionality, not adopt the entire NOIR runtime. Donor Wolverine messages, specifications, tenant hooks, SignalR helpers and generic repositories must either map to existing target interfaces or be replaced with small target-style services. We will not carry the donor framework into Cosmix simply because one page imports it.

One authoritative owner per record

Record or control	Authoritative owner	Integration rule
Accounts sessions devices and access	Existing Cosmix authentication	Reuse current-state checks and permission scopes; no second login store
Employees assignments and HR evidence	Existing HR	CRM owners and project members reference existing employees
Customers companies and contacts	Approved CRM customer master	A contact is not automatically a customer login or a new employee
Item units stores and physical movements	Inventory	Procurement or Operations request stock actions; they do not change balances directly
Approved commercial scope	Sales and Estimation	Preserve approved source/revision references through project handoff
Projects jobs and work evidence	Operations and Projects	Membership and job assignment constrain access
Posted journals and fiscal periods	Accounts	Finance reads the same ledger; it does not create a second accounting ledger
QA checkpoint decisions	Quality assurance	Enforce only approved applicable checkpoints

Shared contracts to settle before parallel work

- Identity mapping: current account to employee, customer and authorised company/department/site scope.
- Business references: source type, source ID and approved revision; avoid loose text as the only transaction linkage.
- Quantity: approved unit and decimal precision where engineering quantities require it. Separate quantity policy from currency rounding.
- Money: amount plus currency and approved rate/version where conversion is needed. Do not add unrelated currencies together.
- Mutation contracts: request key, expected version, trusted actor, audit target and explicit result/error behaviour.
- Events and notifications: publish after commit through a durable retry mechanism where external effects must survive failures.
- Provider and mobile contracts: session expiry, retry behaviour, evidence ownership and data retention.

The target currently exposes IUnitOfWork.SaveChangesAsync(CancellationToken). A module needing several writes, locking, receipts and audit evidence must define and review its transaction boundary; several calls to SaveChanges are not automatically one atomic operation.

4 Exact Donor Reuse Portfolio

Donor capability	Decision	Conditions before acceptance
Data tables forms filters dialogs and date controls	Adapt first	Import only dependencies needed by the first feature; keep target styling and HTTP/security client
CRM contacts companies leads pipeline and activities	First end-to-end port candidate	Map identity/ownership; validate references; use target services migrations permissions and tests
Projects tasks boards members comments and labels	Second substantial port candidate	Map existing employees; enforce membership; add approved commercial handoff where in release scope
Inventory receipts detail confirm/cancel and history	Adapt developed parts	Fix transaction/reference defects and implement the approved store/unit movement model
Product SKU/category components	Selective adaptation	Do not import carts orders promotions or unnecessary retail variants as inventory prerequisites
Dashboard charts and widgets	UI reuse only	Replace demo/commerce calculations with authorised target queries
BOQ/BOM fields and arithmetic	Review and adapt	Approved revisions units costing and source references must be added or corrected

Donor capability	Decision	Conditions before acceptance
Accounting procurement manufacturing/FSM scaffolding	Conditional component reuse	Not ready-made modules; each needs its own approved workflow and posting/authority tests
Auth HR private files and sensitive approval logic	Retain target	Do not replace existing SRS-specific controls with generic donor equivalents
Donor migrations default accounts secrets and retail checkout	Do not import	Produce target migrations from reviewed target models; no imported users or runtime credentials

Extraction procedure for every selected module

1. Freeze the donor revision and record any selected uncommitted repairs in a reviewed patch. No changes are silently treated as part of upstream.
2. Produce a source manifest: file, source revision, dependency, licence/provenance, reuse decision, target destination and known defect.
3. Inventory transitive imports. A page may require permissions, regional settings, table helpers, entity updates and routing, not just one component file.
4. Prefer existing target components. Port missing reusable controls without importing the full donor application/providers.
5. Map DTOs, IDs, errors, server permissions and target HTTP client before connecting screens.
6. Reimplement incompatible infrastructure glue in target conventions. Copying a tested algorithm is different from transplanting its framework.
7. Add target-specific regression tests and isolated SQL/browser checks. Donor passes do not carry over automatically.
8. Deliver an independently usable slice with feature activation, rollback instructions and a requirement-to-test record.

The donor root includes Apache License 2.0. That observation does not establish the provenance or licence obligations of every ported third-party fragment. Retain an approved provenance and dependency inventory before distributing reused code.

5 First Integration Trial and CRM Delivery

Five working day trial

The trial is a time budget, not a promise to finish CRM in five days. We will implement one small, representative target flow: an authorised staff user can list, create, view and edit a contact using selected donor UI while the existing Cosmix login/session continues to work.

The trial includes real target validation, persistence, permissions, actor assignment and error handling. It must not use donor credentials, bypass authentication or return placeholder success.

Proposed trial file boundaries

Backend files will be under the confirmed target: src/Cosmix.Domain/CRM/Contact.cs; src/Cosmix.Application/CRM/Contacts/ContactContracts.cs, ContactService.cs and IContactRepository.cs; src/Cosmix.Infrastructure/Database/Configurations/CRM/ContactConfiguration.cs; src/Cosmix.Infrastructure/Repositories/CRM/ContactRepository.cs; src/Cosmix.Api/Controllers/CRM/ContactsController.cs.

Frontend files will remain under src/modules/crm/pages, components, api, hooks, schemas and types. Existing src/services/api/http-client.ts and src/app/router/AppRoutes.tsx remain the integration points. Shared schema/context/permission files get one named owner and a small reviewed patch.

These filenames are proposed new boundaries, not claims that they already exist. The detailed trial plan must resolve exact DTO fields and interfaces after the review decisions in Section 16.

Trial acceptance

- Existing HR login, MFA, CSRF, refresh and protected HR pages still work under the same contracts.
- Anonymous and unauthorised callers are denied. An authorised user cannot bypass record scope by changing an ID.
- Invalid and duplicate records produce controlled errors, not a database exception or fake success.
- List search, filters, paging and edit states work against real target endpoints.
- Actor identity is server-derived; stale versions and repeated writes have defined behaviour.
- We can account for every imported dependency and preserve the selected source notices.
- The slice passes the approved target tests and a browser walkthrough on desktop/mobile-width web views.

Continue or stop decision

Continue the port if it can fit target conventions without replacing authentication or importing a large unrelated framework. If the trial requires a second identity store, extensive framework adoption or unbounded dependency copying, switch that capability to UI/reference-only reuse and build the smaller target service directly. Record actual effort and re-estimate subsequent work before committing dates.

CRM after the trial

Add companies and linked contacts, lead ownership, source attribution, pipeline stages, activities and authorised reporting. Add controlled contact-to-customer conversion without creating duplicate customer identities. Email/WhatsApp/social intake is a separate connector package; a source dropdown is not a live integration.

Done means the agreed sales users can complete the selected inquiry-to-lead flow with history and access controls. Approved quotation and customer-PO handoff belong to later linked packages, not automatic CRM completion.

6 Inventory Integration and Completion

Inventory is a real donor reuse opportunity, but its two implementations must not be confused. The developed e-commerce area has receipt APIs, connected receipt UI, manual stock movements and history. The newer ERP area has stock indents/transfers and GRN-related models. A transfer marked Completed currently does not execute stock transfer posting.

The e-commerce model stores integer ProductVariant quantities. The SRS needs items, physical/virtual/local/international stores, on-hand stock, issues, returns, transfers, project consumption and aging. We will not rename product variants and claim this is complete Stores/MM.

Recommended inventory sequence

Package	Usable flow	Prerequisite and evidence
INV A References	Item category approved unit and store references	Scope rules; uniqueness; inactive reference behaviour; unit decisions
INV B Ledger foundation	Source-linked movement history and store balances	Decimal precision; atomic posting; idempotency; concurrency
INV C Receipts	Draft receipt review accepted quantities and posting	Valid items/stores; applicable QA; rejection/partial receipt treatment
INV D Issues and returns	Approved demand to issue consumption or return	Project/job link; stock/reservation rules; receiver evidence
INV E Transfers	Request approval dispatch in-transit destination receipt	Source/destination authority; once-only debit/credit; discrepancy handling
INV F Adjustments and reporting	Authorised adjustment availability history and aging	Evidence/reason; finance-approved valuation and aging definitions

What we adapt

Adapt receipt listing/detail and confirm/cancel interactions, useful filters/status labels, history presentation, selected SKU/item controls and applicable test cases. Reuse arithmetic or validation only after it matches approved engineering units and target contracts.

What must change before posting is enabled

The donor confirmation handler skips missing products/variants. Its movement logger saves inside an item loop, so a later failure may follow an earlier committed change. Manual movement also saves the stock change before logging history. These patterns must not be ported into target stock posting.

Validate every line and relevant source before committing anything. A receipt action must persist its accepted quantities, ledger entries, balances, audit and retry receipt within one owned transaction.

Any failure leaves all relevant lines unchanged. A duplicate retry returns the original result; conflicting payload or stale state must not post again.

6 Inventory Posting Rules Continued

Proposed ledger contract for design review

Each posted movement identifies the item, approved unit, store, signed quantity effect, source document/line, operation key, actor and posting time. Balances may be maintained as transactional summaries of the movement ledger, but the two must reconcile. Posted history is append-only; corrections use linked authorised reversals or new movements, not silent edits.

Receipt, issue, transfer and production changes all call this controlled posting boundary. They must not independently edit stock fields. We should expose purpose-specific actions instead of an unrestricted public setter for quantity or store balance.

Transfers need explicit treatment of goods in transit and destination discrepancies. Approval alone changes no physical stock. Dispatch and receiving are distinct events where the approved company process requires them. Do not credit the destination twice or make in-transit goods appear simultaneously available in both stores.

Finance approves cost/valuation and currency treatment; Inventory owns physical quantities. We must agree FIFO/weighted-average or another accepted method, lot/serial requirements, rounding and negative-stock policy before promising the corresponding reports. None of those policy values is invented by this plan.

Required inventory tests

- Two-line receipt: the second line fails; neither line, balance nor confirmation commits.
- Missing/inactive/wrong-scope item or store: controlled failure before posting.
- Same request key and payload: same result, no additional movement. Changed payload: controlled conflict.
- Two simultaneous issues: approved stock policy is preserved; no lost update or accidental negative balance.
- Transfer: source, in-transit and destination effects reconcile; partial receipt/discrepancy follows approved rules.
- Decimal quantities and unit conversions: approved precision is preserved end to end.
- Unauthorised issue, adjustment, transfer or export: denied, including direct API calls.
- Posted correction: original evidence remains readable and the reversal is linked.
- History/report totals reconcile to the posted movements and authorised store balances.

Inventory done condition

Stores staff can execute the approved receipt, issue, return and transfer flows in the target clients, with reconciled balances and evidence. Reports must state their source and cutoff. Until the agreed valuation/aging package passes, do not label financial inventory value or aging complete.

7 Projects Tasks and Operational Handoff

Port the developed project/task UI and applicable domain rules: project listing/details, boards, members, task assignments, comments, labels and due dates. Preserve one employee master and map all owner/member references to target employees.

Add target-side project membership and assigned-task access checks. A client-supplied owner/member ID is not authority to manage a project. File/comment access inherits the permitted project scope. Reassignment, inactive employees and account revocation must have defined behaviour.

The generic donor workspace is not the full ERP project lifecycle. The approved commercial scope/version must be linked when a lead becomes an execution project. Material requests, procurement, production, dispatch and field jobs consume explicit project/source references rather than loosely related names.

Delivery boundary

For a priority CRM/Inventory/Projects release, we can provide operational tasks and source-linked inventory requests without pretending that complete Procurement, Manufacturing or FSM exists. Keep undelivered downstream actions disabled and visibly unavailable, not connected to placeholder success.

Acceptance

- Create a project from an authorised accepted-scope handoff; retain its source/version.
- Use existing employees for ownership/membership and deny unrelated staff access.
- Task create, move, assign, comment and close actions preserve history and valid transitions.
- Repeated or stale actions cannot silently duplicate handoff or overwrite another decision.
- Inventory requests reference the permitted project/job; material posting remains Inventory-owned.
- Applicable project completion evidence/QA is checked according to the signed process.

8 Existing HR and Mobile Foundation

Retain hiring, sensitive changes, compensation approvals, protected files, employee status effects, authentication and organisation masters. Run baseline regression checks around every integration touching shared security, schema or employee references.

Do not claim that retaining HR completes HR. Attendance/face-IN, shifts/rosters, immutable punches, offline/time cases, corrections/month locks, leave/OT, allowances/fuel/loans and payroll-input handoff remain separate packages according to the HR SRS and existing delivery ownership.

The original assignment gives one backend developer HR/security and the other attendance/notifications, with web/mobile owned by the PM. ERP work changes that allocation. Management must explicitly reprioritise, add capacity or defer work; we cannot assign the same developers full-time to both programmes.

Face verification is for check-in only under the existing requirement. No check-out face requirement, attendance hardware integration, unrestricted continuous location tracking or invented payroll formula is added by this plan.

9 Complete SRS Module Roadmap

The following 17 groups preserve the presentation grouping. They are not 17 ready donor modules and do not imply that every group fits the five-month pilot. Every group needs its own approved package, acceptance owner and release allocation.

1 Sales and commercial

Adapt CRM contacts, companies, leads, pipeline and activities. Complete owned multi-source intake, lead/customer conversion, quotation issue/revisions, full customer-PO comparison, mismatch resolution and acknowledged Operations handoff. Acceptance owner: Sales with Operations for handoff.

2 Estimation

Review BOQ fields and arithmetic. Complete approved units, material/source availability, costing/alternatives, margin/tax/currency decisions, frozen approved revisions and quotation linkage. Approved content must not be edited without a controlled revision. Acceptance owner: Estimation with Sales/Finance.

3 Engineering

Review submittal and conversion scaffolding. Complete source/normalised/final values, equipment selection, approved formula versions, defined AUX inputs, retained technical revisions and trusted review/handoff. Factor-only conversion cannot represent every required conversion. Acceptance owner: Engineering.

4 Operations and field service

Adapt project/task capability. Complete approved execution scope, scheduling, job assignment, qualified/available nearby-staff selection, acceptance/decline/timeout/fallback, material/evidence handling and safe closure. Permission checks must restrict staff to their authorised jobs. Acceptance owner: Operations.

5 Inventory and stores

Adapt the developed receipt/history interfaces and selected rules. Deliver references, store ledger, receipts, issue/return, real transfers, adjustments, availability and agreed aging/valuation/reporting as defined in Sections 6 and 6 Continued. Acceptance owner: Stores with Finance for valuation.

6 Procurement

Review supplier and PO scaffolding. Complete approved demand, supplier/agency governance, quotation comparison, selection evidence, value-based approval, PO issue/revisions/acknowledgement, partial receipts, discrepancies and closure. Purchasing cannot directly edit Inventory balances. Acceptance owner: Procurement with Stores/Finance.

9 Complete SRS Module Roadmap Continued

7 Manufacturing

Review BOM/scaling and production-order rules. Complete approved demand and frozen BOM versions, controlled material issue/return, lifecycle-safe concurrent progress, applicable QA/rework,

finished-goods receipt and costing/handoff. Status counters must cause real authorised inventory effects through the ledger boundary. Acceptance owner: Production with Stores/QA.

8 Quality assurance

Review inspection records. Complete approved versioned criteria, trusted inspectors/evidence, defects, corrective work/reinspection and links to the exact received/produced/project version. Enforce only agreed release checkpoints. Acceptance owner: QA and the relevant department.

9 Human resources

Retain existing HR/security rather than importing the generic donor employee directory. Complete the remaining HR v1.2 packages with effective-dated policies, approvals, private evidence, calculations and payroll-input verification. Acceptance owner: HR with Accounts for handoff.

10 Office employee mobile panel

Use the existing React Native client and shared authentication. Deliver owned profile/document requests, attendance/calendar, corrections, leave/OT, own salary effects/claims, tasks/notices and permitted supervisor views. Generic profile pages are not this panel. Acceptance owner: HR and employee representatives.

11 Field and site employee panel

Extend the staff mobile experience for assigned jobs, accept/decline, work/evidence, material reporting, appropriate site/duty presence and resilient sync. Job completion is not an attendance punch. Location and background behaviour require agreed privacy/platform rules. Acceptance owner: Operations/HR.

12 Customer application

Provide verified customer-to-account ownership, complaint/site/evidence submission, receipt/progress timeline, visit scheduling, confirmation/dispute and own history. Never authorise access solely using customerId supplied by the client. Customer app packaging/platform and payment features require explicit scope decisions. Acceptance owner: Customer Service.

9 Complete SRS Module Roadmap Final Groups

13 Accounts

Review account/journal models and calculations. Complete sales invoices linked to approved sources, vendor bills and AP, eligible accounts/open periods, posting and rounding decisions, authorised reversals, authoritative trial balance, AR/AP aging and fiscal closing. Prevent invalid amounts, duplicate payments and invalid invoice transitions. Acceptance owner: Accounts.

14 Finance

Use the same Accounts ledger. Deliver approved financial oversight, cost/margin, tax/deduction, currency/rate governance, approval limits, payroll/period review and reconciled executive KPIs. Do not use mixed-currency invoice totals as revenue or maintain a second financial truth. Acceptance owner: Finance/management.

15 Administration

Retain controlled access administration. Complete authorised access requests, shared references/approval routing ownership, helpdesk with trusted requester/assignee, special tasks/events, governed import/export and reminders. Technical system administration does not automatically grant access to medical/payroll details. Acceptance owner: Administration with each data owner.

16 Superadmin and platform administration

Retain controlled owner bootstrap and privileged access. Complete secrets/provider configuration, environment controls, deployment/backup/restore, operational monitoring, failed-job ownership and security audit. No donor default account is imported and no real owner account is created through this planning task. Acceptance owner: system owner and authorised technical administrator.

17 Shared functions and management visibility

Deliver governed master references, calculations, approvals, files, audit, notifications, connectors, exports, jobs and source-traceable reports across teams. Dashboard widgets may be reused; report meaning and permissions must be implemented. Durable processing, deduplication and reconciliation are part of live integrations, not optional UI polish. Acceptance owner: named shared-service owner with department reviewers.

Dependency order across these groups

Identity/access and authoritative references precede all modules. CRM precedes commercial handoff. Item/store/ledger capability precedes real procurement receipts, production posting and operational material consumption. Approved BOQ/engineering/quotation/customer-PO scope precedes controlled execution. Accounts posting and currency rules precede Finance's authoritative reports. Complaint ownership and job contracts precede customer/field app completion.

10 Channels Providers and Mobile Delivery

Inquiry sources

Plan connectors for the approved sources: manual/web intake, email, WhatsApp API and specifically selected social channels. Do not promise every API without an enumerated provider/channel list and approved access.

Each connector needs a provider contract, credentials and scopes, account ownership, webhook/polling strategy, provider signature validation where available, duplicate-event handling, attachment safety, delivery/error reconciliation and an authorised routing owner. Store original external identifiers and link conversation/thread to lead/customer. A replayed webhook must not create a second inquiry.

Outbound replies and reminders need approved templates/consent rules, durable retries, provider IDs and delivery states. Never send externally before the related business transaction commits. Attendance remains in-app, not an email/WhatsApp attendance workflow.

Jazz SMS OTP

Reuse the existing target authentication/provider boundary. Obtain the vendor's actual API documentation, sandbox access, credentials, sender identity, IP/network requirements,

payload/status/error contract, delivery-receipt support, coverage/rate/cost limits and support escalation process. Credentials stay outside source control.

Approve OTP lifetime, resend/attempt limits, lockout/recovery and privileged-role rules before activation. Test wrong/expired/replayed OTPs, concurrent resends, delayed or duplicate provider responses, outage recovery and redacted logging. No successful mock SMS response is a production delivery guarantee.

Staff and customer apps

The existing mobile project is React Native; web/PWA components do not copy directly into native screens. Reuse DTOs, business contracts and suitable pure validation ideas; write native UI against owned APIs. Decide whether staff share one app with role-specific areas, and whether the customer experience is a separate native app or an approved alternative.

Mobile acceptance includes secure credential storage, lifecycle/session revocation, permissions, interrupted networks, replay-safe submission, evidence upload and device/platform checks. App-store deployment and distribution need separate owners and scheduling.

Provider approval/access and app packaging are external dependencies. If they are not ready, keep affected features disabled and report them as incomplete; do not mask them with demo behaviour.

11 Security and Integrity Release Gates

Use OWASP ASVS as a structured verification reference and the OWASP authorization guidance for least privilege, deny-by-default and every-request permission checks. These references support the checklist; they are not a certification of this project.

Access and privacy

- Derive actor identity from the current authenticated session, not request user/reviewer fields.
- Check action permission and record scope on read/write/list/export/file access, including direct API calls.
- Prevent requester/self-approval where the approved process requires separation of duties.
- Apply current employee/account/session status so a disabled or offboarded person cannot retain access.
- Restrict customer data to owned records and staff jobs to authorised assignments.
- Preserve private HR/document access and separate sensitive DTOs; prevent mass assignment of protected fields.
- Remove donor default/demo credentials and guard integrations/configuration behind appropriate authority.

Transactions and business state

- Valid source/revision and permitted state precede consequential mutation.
- Monetary/quantity validation, approved rounding and currency/unit treatment precede posting.
- Audit, business changes, balances/ledger and retry receipt commit or fail together where required.
- Duplicate and concurrent requests cannot silently post twice or overwrite another approval.
- Notifications/provider effects are emitted only after successful commit with recoverable retry evidence.
- Posted records remain traceable; corrections use controlled reversal/revision, not hidden edits.

Files infrastructure and dependencies

- Validate file type/size and scan/storage access using the existing private-file boundary; verify the real scanner deployment.
- Keep secrets outside Git, use protected transport and narrowly configured origins/cookies.
- Review imported dependencies and actual vulnerability advisories; do not suppress warnings to declare security complete.
- Test backup restoration, least-privilege database/application access, monitoring and incident ownership.
- Review production build/publish/container and migration privileges before deployment.

11 Security Verification and Review Focus

These five failure classes require explicit tests and review, not only happy-path demonstrations.

Failure class	Expected behaviour	Owning package
Another user's customer/project/store ID	Denied or appropriately scoped result without data leakage	Every module's access tests

Failure class	Expected behaviour	Owning package
Duplicate request after network interruption	Same authorised result; no duplicate record/posting; changed payload conflicts	CRM mutations inventory posting and later integrations
Stale/concurrent stock or approval action	Preserve approved invariants and return controlled conflict/retry behaviour	Inventory approvals Projects HR regression
Failure after one line or external call	No partial business commit; recoverable external reconciliation	Inventory Accounts connectors
Revoked role/session and sensitive export/file access	Current authority is rechecked; protected content is not exposed	Shared security HR all module endpoints

Acceptance includes negative authorisation tests, isolated SQL atomicity/concurrency tests, connected browser/native checks and peer review of consequential changes. High-impact unresolved access, privacy or financial/stock integrity findings block release of the affected workflow. A passing build cannot override those gates.

Privileged/approval, stock-posting, payment and customer-evidence paths receive a reviewer other than the implementer. Arrange an independent pre-production security assessment where feasible; that does not replace internal tests.

12 Three Developer Capacity and Delivery Options

Three full-time developers over five months provide 15 gross developer-months, not 15 months of uninterrupted feature work. Meetings, learning, reviews, support, testing, leave, integration and rework reduce usable delivery capacity. We have not measured velocity or produced defensible full-SRS effort estimates yet.

Option A recommended ERP foundation pilot

Prioritise existing HR/auth regression, CRM, item/store references, controlled inventory receipt/issue/return and the agreed transfer package, Projects/tasks and limited source-linked handoff/reporting. Deliver the agreed channels/mobile slice only if its scope and external dependencies fit the measured budget. Full attendance/payroll, complete procurement/manufacturing/accounting/FSM and both complete mobile experiences are not silently included.

Option B service and mobile priority

Prioritise existing security, customer complaint ownership, manual authorised dispatch, field staff job flow, evidence/confirmation and the agreed customer/staff app experience. Inventory and CRM are limited to the references/flows needed by that service release. Automatic nearest-staff matching requires separate skills/availability/location/provider decisions. This option consumes mobile/backend capacity and postpones broader ERP depth.

Option C complete SRS commitment

Do not promise this with current evidence. Break all packages into estimated, testable deliveries, identify missing decisions/providers, then change capacity, time, scope or purchase a proven compatible system through a separate fit-gap evaluation. Adding random repositories is not a substitute for that decision.

Management selects one release scope and explicitly records deferred requirements. The full programme roadmap remains visible regardless of pilot choice.

13 Proposed Five Month Pilot Sequence

This is a planning allocation for Option A, not a validated estimate or a completion guarantee. Weeks are relative to an approved start; no start date is assumed. Five calendar months is roughly 20 to 22 weeks, so the exact working-day calendar must be confirmed.

Window	Focus	Evidence to exit
Week 1	Baseline source manifest scope/security contracts and CRM trial	Known dependency cost; identity retained; trial accepted or reuse strategy changed
Weeks 2 to 5	Selected CRM flows and shared UI	Connected accepted contacts/companies/leads scope with role/ownership tests
Weeks 6 to 11	Inventory references ledger receipts and agreed issue/return/transfer scope	SQL posting reconciliation rollback/retry/concurrency and stores-user acceptance
Weeks 12 to 15	Projects/tasks and approved inventory/commercial references	Authorised members; acknowledged handoff; no placeholder downstream success
Weeks 16 to 18	Agreed reporting and one bounded channel or mobile slice	Only measured feasible scope; real provider/client evidence where included
Weeks 19 to 22	Hardening UAT defects rehearsal deployment and buffer	Security/integrity gates passed; restore verified; signed pilot acceptance

The order expresses dependencies. If CRM effort overruns its budget or inventory policy/ledger work proves larger, management reduces the release scope or revises the date. We do not consume all UAT/security time to keep an unreviewed feature list unchanged.

Review rhythm

Daily short coordination on shared files and blockers. Weekly demonstration of a complete flow, not a screen count. Fortnightly release/backlog review with requirement IDs, acceptance evidence, unresolved defects and updated effort. New CEO requirements enter a change record with scope/date/capacity impact.

14 Ownership and Work Controls

Suggested allocation, subject to actual skills and the existing HR/attendance ownership agreement:

- Developer 1 owns target auth/security/HR preservation, authoritative references and shared contracts. Reviews sensitive/stock consequential changes and coordinates schema ownership.
- Developer 2 owns the current selected ERP backend package: CRM, then Inventory, then Projects. They cannot simultaneously retain a full separate attendance programme without replanning.
- Developer 3 or the PM owns web/client adaptation, native delivery and connected acceptance demonstrations. Full web plus two complete mobile apps is not assumed to fit one person's concurrent capacity.
- Testing is part of every task. The other backend developer reviews high-risk work; the PM/domain owner performs UAT. No fourth dedicated QA role is assumed.

Only one owner edits the migration snapshot per merge window. At most one heavy business integration package plus a bounded shared/client task is active unless capacity is explicitly changed. No developer silently changes another module's shared contract.

15 Implementation Packages and Verification Steps

This master plan is for review. After its decisions are approved, prepare a detailed module design and exact implementation plan for each package. Do not treat future proposed file names as existing interfaces or approved schemas.

Task 1 preserve and reproduce the target baseline

Files to inspect: confirmed target AGENTS.md, README.md, docs/Architecture.md, docs/Work-Ownership.md, Cosmix.Backend.sln, authentication/permission classes and CosmixDbContext. Record the working tree and protect the existing Cosmix.Api.http change.

- Review item Record target/donor commit identities and selected donor patch; list dependencies and licences.
- Review item Run the approved target Release build and web/mobile verification without starting against an unapproved database.
- Review item Capture target auth/HR acceptance limits and create an isolated verification environment.
- Review item Agree test-project or external-harness permission before introducing test infrastructure.

Backend verification command: dotnet build Cosmix.Backend.sln -c Release. Web/mobile expose npm run verify in their package scripts; use the pinned target Node/package manager and lockfile. The target solution currently has no test projects, so dotnet test on that solution alone does not establish behavioural coverage.

Task 2 first UI and CRM trial

Consumes: existing authentication/current account, approved permission/scope contract and existing frontend HTTP client. Produces: a protected contact list/create/detail/edit flow with target records and error/version/retry behaviour.

Proposed files are listed in Section 5. Reference donor Crm handlers/entities, CRM frontend features/services and only required UI controls. Do not copy the donor apiClient or auth providers.

- Review item Write failing target cases for denied access, scoped reads, invalid/duplicate contact, stale edit and replay.
- Review item Confirm those cases fail for the intended missing behaviour, not an unrelated setup error.
- Review item Implement the smallest target-style service/controller/repository/mapping and reviewed additive migration.
- Review item Adapt the selected page/dialog and connect through the target HTTP client; register actual routes.
- Review item Run automated checks, isolated SQL and browser flows; measure dependencies and effort.
- Review item Review and accept the trial before expanding CRM or importing another module.

Task 3 inventory design and posting package

Consumes: approved item/unit/store definitions, source references, target security and reviewed transaction/idempotency contracts. Produces: one controlled source-linked ledger posting boundary used by receipts/issues/returns/transfers.

Proposed boundaries: Domain/Inventory; Application/Inventory/Items, Stores, Ledger, Receipts, Issues, Transfers; Infrastructure/Database/Configurations/Inventory and Repositories/Inventory; Api/Controllers/Inventory; frontend src/modules/inventory. Final entities/interfaces are approved in that package's design, not guessed from donor retail classes.

- Review item Define quantity/unit/valuation and state decisions with Stores/Finance.
- Review item Write failing SQL tests for multi-line rollback, replay, missing references and simultaneous issues.
- Review item Implement the owned transaction, movement/balance/audit/retry persistence and proper reference validation.
- Review item Adapt receipt/history UI; add the missing engineering store/issue/return/transfer interfaces.
- Review item Reconcile movement/history/balances and demonstrate the agreed lifecycle with stores users.

15 Implementation Packages Continued

Task 4 projects and source handoff

Consumes: existing employees, accepted commercial source/version and inventory request contract. Produces: authorised projects/members/tasks with retained source handoff and controlled material requests.

Proposed boundaries: Domain/Projects; Application/Projects; Infrastructure project configurations/repositories; Api/Controllers/Projects; frontend src/modules/projects. Adapt donor Pm features/UI; do not create another employee table.

- Review item Write failing membership, inactive-assignee, duplicate-handoff and stale-task tests.
- Review item Port usable task/project behaviour under the approved target identities and permissions.
- Review item Connect lists/boards/comments and approved handoff/material-reference flows.
- Review item Verify permitted/denied API access, client workflows and retained history.

Task 5 providers mobile and later ERP packages

Consumes: the package's signed scope, live provider access where needed, owned records and shared security/posting contracts. Produces: accepted real integrations or disabled clearly incomplete features.

- Review item Prepare separate designs for each connector/mobile/Accounts/Procurement/Manufacturing/FSM package.
- Review item Map existing donor components and defects to target requirements; reject unrelated infrastructure copying.
- Review item Write negative-access, retry/concurrency, source-version and failure/rollback tests before consequential implementation.
- Review item Implement only the approved package and reconcile its cross-module effects.
- Review item Demonstrate its full selected flow and record exact limitations/deferred requirements.

Task 6 release rehearsal and acceptance

- Review item Complete code/security review and address high-impact findings on released workflows.

- Review item Rehearse additive upgrade against a verified production-like database copy, with owned target verification.
- Review item Test application rollback compatibility and restore recovery; do not drop populated tables as a casual rollback.
- Review item Run connected web/native UAT, real configured providers, reports and access-denial cases.
- Review item Capture signed acceptance, operating/support runbooks and release approval.

No commit, merge, push, database update or deployment happens as part of creating this plan. Future commit/merge actions follow the user's approved workflow and preserve unrelated changes.

16 Decisions Needed Before Implementation

Decision	Owner	Timing and blocked work
D01 target folders	User confirmed	Locked to Cosmix_Erp_software backend/web/mobile; other copy untouched
D02 first release scope and five month meaning	CEO PM department owners	Before date commitment; choose Option A B or a separately estimated full scope
D03 staff roles record scopes and approval authority	Admin HR department owners	Before any selected feature's mutation/access design
D04 customer employee company and master identity mapping	Backend owners with Sales HR	Before CRM models and project/customer ownership
D05 units precision stores stock policy valuation and aging	Stores Engineering Accounts Finance	Before ledger/report schema and consequential inventory posting
D06 provider list access credentials and mobile packaging	PM technical owner vendors	Before real channels OTP face/location and customer app acceptance
D07 automated test infrastructure and environment	PM user backend owners	Before integration; explicitly approve test projects or a retained isolated harness
D08 developer reassignment and QA review capacity	PM team	Before combining HR/attendance and ERP commitments
D09 signed source requirements versus design additions	CEO HR department owners	Before locking each module design; no invented SLA thresholds or formulas

Approval should state the selected option, included/excluded flows, department owners, test approach and permitted execution method. Approving this plan does not approve unknown database access, real owner creation or unattended deployment.

17 Change Migration and Release Safety

Freeze the donor and maintain a component provenance manifest. Preserve the earlier uncommitted donor repairs separately from upstream. A reproducible donor state must be recorded before copying any selected source into the target.

Generate new target migrations from reviewed target models. Never import NOIR migration history, its tenant registry, seeded accounts or runtime connection settings. Verify that the target change is additive or has an explicitly reviewed compatibility/data conversion plan. Applied target migrations remain unchanged.

Use isolated tests first. Before an approved real upgrade, verify the absolute connection/database identity, take an approved backup, confirm restore viability and review the actual SQL. A folder called original does not identify a database connection. Starting an app that automatically migrates/seeds is a side effect requiring the same scrutiny.

Keep changed APIs backward compatible for deployed web/mobile clients where possible. If a breaking contract is necessary, coordinate client rollout and document the compatibility window. Use feature gates for incomplete modules; gates are not a substitute for backend permission checks.

Define an application rollback and database recovery strategy per migration. New data may make a destructive Down migration unacceptable. Never use git reset/checkout to discard user work or casually drop populated business tables.

Definition of done for a released module

- Every selected requirement links to a demonstrated flow and test/evidence.
- Connected client/API/database, approved role/scope, business transitions and reference checks work.
- Audit, retries, concurrent writes and failure recovery behave as agreed.
- Actual physical/financial effects reconcile; a status label is not the effect.
- No high-impact unresolved security/integrity defect remains on the released flow.
- Reports/export/files expose only permitted data and use approved calculations.
- Operators can monitor, recover and support the module with a documented runbook.
- Domain owner signs acceptance; remaining requirements are named, not hidden behind a completion percentage.

18 Your Review Checklist

- Review item I agree the confirmed original Cosmix backend remains the main system.
- Review item I agree donor reuse includes UI CRM Projects and developed Inventory parts, not wholesale identity/database replacement.
- Review item I understand Inventory still needs engineering store/unit/ledger and posting work.
- Review item I understand Accounts Procurement Manufacturing FSM and complete mobile panels remain programme packages, not delivered donor modules.
- Review item I approve the first CRM trial and its continue/stop criteria.
- Review item I have selected the five-month release option and explicit exclusions.
- Review item I have confirmed developer allocation, reviewer/UAT owners and test infrastructure.
- Review item I have assigned decision owners for units valuation approvals provider/mobile scope and remaining HR policy.
- Review item I understand this is a review plan, not a production-readiness certificate or implementation already performed.

Record your review

Selected release option: _____

Included flows and explicit deferrals: _____

Approved verification approach: _____

Review owner and review date: _____

Requested changes before implementation: _____

19 Source Map and Verification References

Source requirements

- Desktop/SOFTWARE REQUIREMENTS SPECIFICATION.docx: original draft, including inventory/stores/transfer/aging and full cross-department scope. AI requirements are excluded from this programme.
- Desktop/Cosmix_ERP_FSM_Detailed_SRS_v0.4.docx: AI-free expanded module map and common contracts; proposed additions still require approval.
- Downloads/HR_Attendance_Employee_Mobile_SRS_v1.2.docx: detailed HR/mobile requirements and unresolved policy register.
- Cosmix_new/HMS_ERP_FSM_Comprehensive_Development_Report.docx: supporting claimed development report, not acceptance evidence.

Target references under the confirmed original backend

- AGENTS.md, README.md, docs/Architecture.md and docs/Work-Ownership.md.
- docs/SRS-Module-Map.md and existing HR/auth verification records.
- src/Cosmix.Application/HR/Employees/EmployeeHiringService.cs and EmployeeUpdateService.cs.
- src/Cosmix.Application/Authentication/Access/AccessPermissionCatalog.cs.
- src/Cosmix.Application/Common/Interfaces/IUnitOfWork.cs.
- src/Cosmix.Infrastructure/Database/CosmixDbContext.cs and existing migrations.

Donor locations under Cosmix_new/code

- UI: src/NOIR.Web/frontend/src/uikit and the dependencies imported by selected components.
- CRM: src/NOIR.Application/Features/Crm; src/NOIR.Domain/Entities/Crm; frontend src/portal-app/crm and src/services/crm.ts.
- Projects: src/NOIR.Application/Features/Pm; src/NOIR.Domain/Entities/Pm; frontend src/portal-app/pm and src/services/pm.ts.
- Inventory: src/NOIR.Application/Features/Inventory; Domain/Entities/Inventory; frontend src/portal-app/inventory and src/services/inventory.ts.
- Posting risk: ConfirmInventoryReceiptCommandHandler.cs, CreateStockMovementCommandHandler.cs and Infrastructure/Services/Inventory/InventoryMovementLogger.cs.
- ERP documents: Application/Features/Stock and Domain/Entities/Stock; Product/ProductVariant.cs uses integer stock.
- Conditional reuse: Application/Features/Accounting, Estimation and Manufacturing plus relevant direct endpoints and domain models.

Prior audit and repair records

Desktop/Cosmix_New_Code_Review_and_SRS_Gaps_2026_10_12.docx is the detailed pre-repair audit. Donor docs/BUILD_REPAIR_STATUS_2026_10_12.md records subsequent build/schema fixes and remaining limitations. Cosmix_new/analysis retains the scoped review notes, build/test logs and SQL evidence. Do not confuse those donor results with target acceptance.

Security references

OWASP ASVS: https://owasp.org/projects/asvs

OWASP Authorization Cheat Sheet:
https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html

These primary references provide verification/access-control guidance. The proposed gates and schedule are engineering recommendations for review, not statements that these controls have already passed in the target.

Plan self review

All 17 programme groups are mapped. CRM and Inventory are clearly separated into reuse and missing behaviour. The user-confirmed target supersedes the earlier external-folder assumption. No fixed company policy, effort-saving percentage or full-SRS five-month guarantee is invented. Security, transaction/retry and data ownership dependencies have explicit gates. The first-wave task boundaries are defined; detailed module DTO/signature/schema plans follow decision approval instead of fabricating implementation-ready interfaces.